PHP2Shell

CVE-2026-109618, CVE-2026-109619

Tomas Vana 25853856

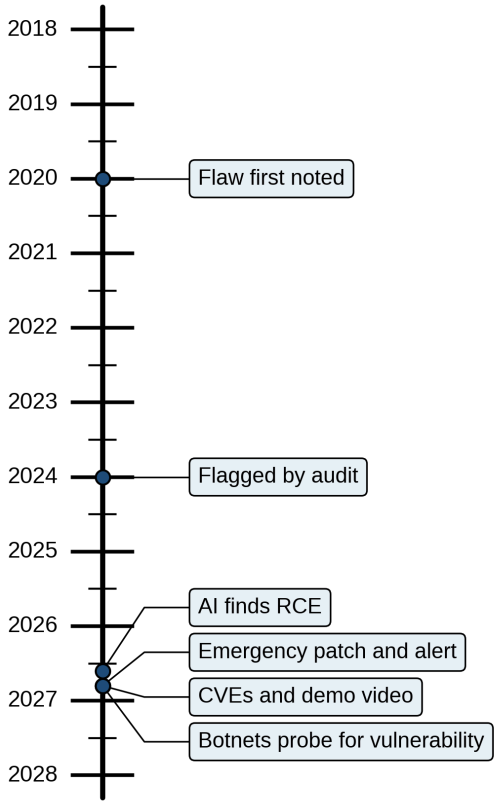
Threat Analysis

PHP2Shell is a pair of memory safety flaws in the PHP runtime, allowing unauthenticated web requests to execute code remotely before the web server does.

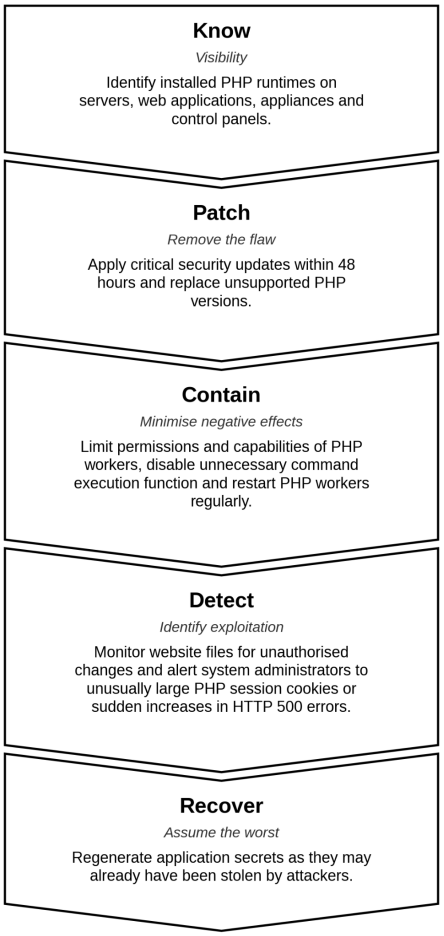
By sending a multipart file upload that triggers an out-of-memory (OOM fault) in PHP's underlying C engine, the server's heap is corrupted and freed memory can be gained control of. This allows the attacker to execute code as the web user or extract process memory that stores session tokens, passwords, and API keys. Because of this failure beneath the application layer of HTTP, logging systems cannot capture evidence of the exploit.

Incident Details

The vulnerability was identified twice, in 2020 and 2024, but an exploit was not identified due to the expected complexity of its nature. It was weaponised using frontier AI technologies by Calif and Open AI in late 2026, with further methods of exploitation contributed by Wiz. This information was leaked approximately two months later, which prompted emergency fixes and the creation of CVE identifiers.



Defense Strategy



Defences

> Two months of coordinated disclosure.
> Additional CDN firewall rules.
> Source backports of PHP.

Limitations

> No setting configuration with existing PHP runtimes can patch the vulnerability.
> Modified multipart uploads can bypass web application firewall (WAF) rules.
> The memory leak exploit executes no code so endpoint tools cannot identify it.
> Half of the internet's PHP webpages are not yet updated.

Impact and Assessment

By 23 October, botnets including a Mirai variant were attempting to exploit the flaw, yet no successful compromise was confirmed. The primary impact of the vulnerability was the precautionary downtime across millions of PHP servers. For example, European government, school and hospital websites and 32 UK services temporarily went offline.

Exposure to the vulnerability had particularly negative effects on smaller organisations, which could include many Aboriginal and Torres Strait Islander community health services, councils and art centres. Successful exploitation of these services could lead to breaches in personal and cultural data, undermining Indigenous Data Sovereignty and control over Indigenous communities data. These communities also have a remote digital inclusion gap of 24.4 percentage points compared with 7.5 nationally, meaning they face greater barriers to accessing local IT support required to respond to incidents.

References

ARC Center of Excellence for Automated Decision-Making and Society. (2021, September 10). *Mapping the Digital Gap*. ADM+S Centre. https://www.admscentre.org.au/mapping-the-digital-gap/

Australian Signals Directorate. (2025). *Essential eight maturity model and ISM mapping | cyber.Gov.au*. Cyber.Gov.Au. https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/essential-eight/essential-eight-maturity-model-and-ism-mapping

Ionut Arghire. (2026, October 21). *PHP2Shell patches land as first exploitation attempts hit sensors*. SecurityWeek. https://www.securityweek.com/php2shell-patches-land-as-first-exploitation-attempts-hit-sensors/

Kovacs, E. (2026, October 23). *Mirai botnet operators join PHP2Shell attacks as ASLR bypass exploits emerge*. SecurityWeek. https://www.securityweek.com/mirai-botnet-operators-join-php2shell-attacks-as-aslr-bypass-exploits-emerge/

Maiam nayri Wingara Indigenous Data Sovereignty Collective. (2018). *Key principles*. Maiam Nayri Wingara. https://www.maiamnayriwingara.org/key-principles

SentinelOne. (2026, October 21). *Stopping PHP2SHELL: How SentinelOne protects customers from this attack technique*. SentinelOne. https://www.sentinelone.com/blog/stopping-php2shell-how-sentinelone-protects-customers-from-this-attack-technique/

Sergiu Gatlan. (2026, October 21). *PHP ships emergency patches for critical PHP2Shell flaws*. BleepingComputer. https://www.bleepingcomputer.com/news/security/php-ships-emergency-patches-for-critical-php2shell-flaws/